
SESIÓN 1 DE 6 · 5 HORAS · BLOQUE 1: 2H15 · DESCANSO 30 MIN · BLOQUE 2: 2H15

TÉCNICAS CRIPTOGRÁFICAS

COOPABURRÁ CIFRA EL DISCO, EL CANAL Y LOS RESPALDOS. ¿POR QUÉ NO PUEDE PROBAR NADA?

SIO0010 · Técnicas Criptográficas · Especialización en Seguridad de la Información de las Organizaciones · Facultad de Ingeniería · Institución Universitaria de Envigado

SECCIÓN

01

ENCUADRE DEL MÓDULO

Qué vamos a hacer en seis sesiones, qué no, y cómo se evalúa

AGENDA DE LA SESIÓN

Cinco horas en dos bloques. El primero fija el lenguaje y las reglas del oficio; el segundo ataca la pieza de la que todo depende y que casi nadie mira: la llave.

BLOQUE	MINUTOS	CONTENIDO	MODALIDAD
Bloque 1	0 – 45	Encuadre del módulo, del caso y de la evaluación	Magistral
	45 – 90	Vocabulario, los cuatro servicios y el ejercicio relámpago	Magistral y taller
	90 – 135	Las reglas del oficio, los modelos de ataque y la vida útil del secreto	Magistral
Descanso	30		
Bloque 2	0 – 50	La llave: entropía, generadores y dos catástrofes reales	Magistral y demostración
	50 – 95	De César a AES: sustitución, transposición, Enigma y el cuaderno de un solo uso	Magistral
	95 – 125	Laboratorio 1, con ejercicio en Python	Laboratorio
	125 – 135	Cierre, entrega y trabajo independiente	Magistral

AL FINAL DE ESTA SESIÓN PODRÁS...

- 01 Distinguir los cuatro servicios y decir cuál falla en un caso concreto**
Confidencialidad, integridad, autenticidad y no repudio no son sinónimos, y confundirlos es el error que explica el caso de Coopaburrá.
- 02 Explicar por qué un algoritmo correcto puede dejar a una organización indefensa**
HMAC-SHA256 no está roto. La aplicación de Coopaburrá lo usa. Y aun así cualquiera puede firmar operaciones.
- 03 Evaluar si una llave es una llave de verdad**
De dónde salió, cuánta entropía tiene, quién la conoce y cuánto tiempo va a seguir sirviendo.
- 04 Reconocer por qué fracasan los cifrados clásicos y por qué eso todavía importa**
Los errores de 1863 se siguen cometiendo en 2026, solo que con nombres nuevos.
- 05 Levantar el inventario criptográfico de una organización**
Es el hallazgo H8 del caso, la primera entrega del producto y lo que Coopaburrá no tenía.

LO QUE NO VAMOS A VER AQUÍ, Y POR QUÉ

Un módulo de dos créditos obliga a escoger. Estas exclusiones son deliberadas y conviene decirlas en voz alta el primer día para que nadie espere algo que no va a llegar.

// NO VAMOS A ESCRIBIR ALGORITMOS DESDE CERO

Nadie en su vida profesional va a escribir AES. Sí lo van a elegir, implementar con librerías estándar, configurar y auditar, que es más difícil y menos enseñado.

Por eso cada laboratorio incluye un ejercicio en Python: implementar, medir y analizar.

// NO VAMOS A HACER CRIPTOANÁLISIS MATEMÁTICO

Romper RSA es un curso de maestría. Sí vamos a ver los fundamentos: aritmética modular, factorización y logaritmo discreto, con números pequeños.

Y sobre todo, a reconocer cuándo un sistema es vulnerable por cómo está usado, que es de donde vienen casi todas las fallas.

// NO VAMOS A VER CADENA DE BLOQUES NI MONEDAS DIGITALES

Usan criptografía, pero el problema que resuelven no es el de Coopaburrá.

Si alguien quiere profundizar, se puede orientar como lectura independiente.

// NO VAMOS A REPETIR GESTIÓN DE RIESGOS NI MARCO LEGAL

Ustedes ya vieron los dos módulos, y conmigo.

Los vamos a usar todo el tiempo como herramienta: para priorizar hallazgos y para sustentar el valor probatorio. Pero no los vamos a explicar otra vez.

DE DÓNDE VIENEN USTEDES

Este módulo no arranca en cero. Arranca sobre dos cosas que ya construyeron, y las va a usar desde la primera entrega.

// LO QUE TRAEN DE GESTIÓN DE RIESGOS

Saben identificar un activo de información, valorarlo y estimar el riesgo sobre él.

Saben que un control se justifica por el riesgo que reduce, no por lo moderno que suene.

En este módulo, la criptografía es exactamente eso: un control. Y como todo control, se prioriza.

// LO QUE TRAEN DE MARCO LEGAL

Conocen la Ley 1273, la Ley 1581 y el régimen de protección de datos.

Saben qué es un deber de custodia y qué consecuencias tiene incumplirlo.

Aquí agregamos la pieza que faltaba: la Ley 527 y el valor probatorio de lo que se firma electrónicamente.

// LA CONSECUENCIA PRÁCTICA

Cuando lleguen a la hoja de ruta de Coopaburrá, nadie les va a enseñar a priorizar: ya saben. Lo que este módulo agrega es el criterio técnico para saber qué tan grave es cada hallazgo y cuánto cuesta arreglarlo.

CÓMO SE EVALÚA ESTE MÓDULO

Una sola nota de 0.0 a 5.0, con 3.5 como mínimo aprobatorio, compuesta por los tres tipos que exige la carta descriptiva del módulo.

TIPO	PESO	INSTRUMENTOS	CUÁNDO
De conocimiento	30 %	Dos evaluaciones cortas sobre contenido	Sesiones 3 y 6
De desempeño	30 %	Seis laboratorios, 5 % cada uno. Se evalúa la ejecución y el análisis, no el resultado	Todas
De producto	40 %	Informe de aseguramiento criptográfico de Coopaburrá, 30 %, y su sustentación, 10 %	Por partes

// LA REGLA QUE MÁS IMPORTA

El informe se construye por partes a lo largo de las seis sesiones y cada parte se realimenta antes de la siguiente. No existe la opción de escribirlo el último fin de semana: las entregas parciales tienen fecha.

LAS SEIS SESIONES DE UN VISTAZO

SESIÓN	TEMA	HALLAZGO DEL CASO	ENTREGA
1 · hoy	Servicios, reglas del oficio y la llave	H8 · No hay inventario	—
2	Cifrado simétrico y sus errores clásicos	H3 y H4 · Disco y respaldos	Parte 1 · Inventario
3	Resúmenes, autenticación de mensajes y contraseñas	H1 y H2 · Contraseñas y firma	Parte 2 · Datos en reposo
4	Llave pública, curvas elípticas y firma digital	H2 y H7 · No repudio	Parte 3 · Contraseñas y firma
5	Certificados, infraestructura de llave pública y canal seguro	H5 · Autoridad interna	Parte 4 · Certificados y llaves
6	Gestión de llaves, Ley 527, post-cuántica y sustentación	H6 y H7 · Cajeros e hipotecas	Partes 5 y 6 · Hoja de ruta

SECCIÓN

02

EL CASO Y LA PREGUNTA

Coopaburrá · Treinta y ocho transferencias que nadie puede probar

COOPABURRÁ

Cooperativa financiera de Itagüí, nacida en 1978 como fondo de empleados de las textileras y vigilada por la Superintendencia Financiera desde 1997. Es la organización sobre la que ustedes trabajan durante los seis encuentros. Todos los artefactos que produzcan se refieren a ella.

142.000

ASOCIADOS
ACTIVOS

\$1,4 B

EN ACTIVOS
ADMINISTRADOS

32

CAJEROS
PROPIOS

20

AÑOS DEL CRÉDITO
MÁS LARGO

0

INVENTARIO DE
LLAVES

// LO QUE LA ORGANIZACIÓN SÍ TIENE

Criptografía en todas partes: cifrado de disco en los servidores, canal cifrado en el portal, respaldos cifrados, llaves en los 32 cajeros y firma de operaciones en la aplicación móvil.

Una política de seguridad aprobada en 2019 que ordena cifrar.

// LO QUE LA ORGANIZACIÓN NO TIENE

Ningún inventario de llaves ni de certificados. Ningún custodio designado. Ninguna ceremonia documentada.

Ninguna forma de demostrar que un registro no fue alterado.

Ningún responsable de seguridad de la información: la función la ejerce de hecho el Jefe de Infraestructura.

LA CRONOLOGÍA DE OCHO SEMANAS

FECHA	QUÉ PASÓ
12 de enero	Una asociada reclama una transferencia de \$1.850.000 que no hizo. Se radica como reclamo ordinario.
19 de enero	Van nueve reclamos. Todos de la aplicación móvil. Todas las transferencias salieron hacia tres cuentas de otra entidad.
23 de enero	Los registros muestran las operaciones como correctamente autenticadas. Ninguna alerta se disparó.
27 de enero	El proveedor informa que la aplicación firma con una clave incrustada en el código, igual para todos los usuarios.
30 de enero	Se bloquean las transferencias externas por la aplicación. En plena quincena.
2 de febrero	38 reclamos por \$71.400.000. Se reintegra el dinero. Cuatro asociados demandan de todos modos.
5 de febrero	El apoderado pregunta cómo se prueba que las operaciones no las hizo el titular. Nadie sabe responder.
9 de febrero	El comité ordena un diagnóstico criptográfico completo. Ahí entran ustedes.

EL CORREO QUE EXPLICA TODO EL CASO

Documento 2 del expediente. Correo de la fábrica de software, 27 de enero de 2026.

CORREO DE BITLAB S.A.S. • 27 DE ENERO DE 2026

«...confirmamos que el esquema de firma de operaciones utiliza HMAC-SHA256 con una clave compartida provisionada en tiempo de compilación. Esta decisión se tomó en 2023 de común acuerdo para evitar el costo de una infraestructura de llave pública y agilizar la salida a producción. El alcance contratado no incluía gestión de llaves...»

// LO QUE ESTÁ BIEN

HMAC-SHA256 es un mecanismo correcto, moderno y ampliamente recomendado.

No está roto. No hay ningún ataque práctico contra él.

Si ustedes auditaran solo el algoritmo, este sistema pasaría.

// LO QUE ESTÁ ROTO

La llave es una sola para los 142.000 asociados.

Viaja dentro del paquete que cualquiera descarga de la tienda de aplicaciones.

Lleva ahí desde marzo de 2023 y nunca se ha cambiado.

No hay forma de saber cuál usuario firmó qué.

LA POLÍTICA DE CIFRADO, COMPLETA

Documento 3 del expediente. No es un extracto: es el artículo 14 íntegro de la Política de Seguridad de la Información aprobada en 2019 y vigente el día del incidente.

POLÍTICA DE SEGURIDAD DE LA INFORMACIÓN • 2019 • ARTÍCULO 14

«Artículo 14. Cifrado. Toda información confidencial de la Cooperativa deberá ser cifrada en reposo y en tránsito utilizando algoritmos de reconocida robustez. La Jefatura de Infraestructura velará por el cumplimiento de esta disposición.»

// POR QUÉ ESTA POLÍTICA NO SIRVE

No dice qué algoritmos. No dice qué longitudes de llave. No dice quién custodia las llaves. No dice cada cuánto se rotan. No dice qué pasa cuando el custodio se va de la organización. No dice cómo se verifica el cumplimiento. Es una política que no se puede auditar, y por lo tanto no se puede incumplir: no hay contra qué contrastarla.

EL INVENTARIO DE LLAVES, ÍNTEGRO

Documento 5. Esto es todo lo que Infraestructura pudo entregar cuando el comité pidió el inventario criptográfico, el 11 de febrero.

CORREO DE LA JEFATURA DE INFRAESTRUCTURA • 11 DE FEBRERO DE 2026

Certificado del portal (vence en junio).
Llaves de cajeros (las cargó el proveedor).
Llave de respaldos (está en el servidor).
Certificado del correo (lo renueva el proveedor de correo).
Pendiente confirmar si la aplicación móvil usa llaves.

// LA MAGNITUD

Cinco líneas escritas en un correo. Ese es el inventario criptográfico completo de una entidad vigilada por la Superintendencia Financiera que administra 142.000 asociados y 1,4 billones de pesos. La última línea —«pendiente confirmar si la aplicación móvil usa llaves»— se refiere al canal donde ocurrió el fraude.

CÓMO SE CONSTRUYE UN INVENTARIO CRIPTOGRÁFICO

Nadie tiene la lista completa: el inventario se arma cruzando fuentes, y cada una revela algo distinto.

FUENTE	QUÉ REVELA	SU LÍMITE
Barrido de certificados y del canal seguro	Versiones, suites, emisores y vencimientos de todo lo que expone un puerto	Solo ve lo que está en la red
Revisión de configuraciones y guiones	Algoritmos, modos y dónde se guarda cada llave	Exige acceso y saber leerlas
Búsqueda en el código y los repositorios	Llaves escritas en el código, constantes y bibliotecas usadas	Solo lo que se tiene en fuentes
Consolas de llaves y módulos de hardware	Qué llaves existen formalmente y quién puede usarlas	Solo lo que ya se gestiona bien
Entrevistas y contratos con proveedores	Lo que ninguna herramienta ve: quién custodia qué y desde cuándo	Depende de la memoria de las personas

// LA REGLA DEL INVENTARIO

Ninguna fuente basta sola, y **las contradicciones entre fuentes son hallazgos**: la sal declarada que no aparece en los datos, por ejemplo. Es exactamente lo que van a encontrar en la sesión 3.

EL ALGORITMO DE COOPABURRÁ ESTABA BIEN ESCOGIDO. LO QUE NADIE ADMINISTRÓ FUE LA LLAVE.

Ese es el patrón de casi todas las fallas criptográficas reales, y es el hilo de las seis sesiones. La criptografía moderna casi nunca se rompe por matemáticas: se rompe por generación de llaves predecible, por llaves compartidas donde debía haber llaves individuales, por llaves que nunca se rotan y por llaves guardadas al lado de lo que protegen. Hoy vamos a aprender a mirar ese lado del problema.

SECCIÓN

03

QUÉ PROMETE LA CRIPTOGRAFÍA

Cuatro servicios distintos que no se sustituyen entre sí

EL VOCABULARIO MÍNIMO DEL MÓDULO

Seis sesiones hablando de lo mismo exigen usar las palabras con precisión. Estas son las que se usan en todo el módulo y el sentido exacto en que se usan: la mitad de los malentendidos de una auditoría empiezan aquí.

TÉRMINO	QUÉ SIGNIFICA AQUÍ	EJEMPLO EN EL CASO
Texto claro y texto cifrado	El dato legible, y el mismo dato después de cifrarlo. Al cifrado también se le llama criptograma	El volcado de la base antes y después del guion de respaldo
Algoritmo o cifra	El procedimiento. Se publica y se estudia: por Kerckhoffs, no es secreto	AES-256 en el respaldo, SHA-1 en las contraseñas
Llave	El único dato secreto. Toda la seguridad descansa en ella	La del respaldo, guardada en un archivo de texto al lado
Espacio de llaves	Cuántas llaves posibles admite el algoritmo. Se expresa en bits	256 bits en el respaldo: tamaño correcto, custodia pésima
Criptografía, criptoanálisis y criptología	Diseñar sistemas; atacarlos; y la disciplina que abarca las dos	Este módulo es criptografía aplicada con criterio de criptoanalista
Ataque	Cualquier forma de obtener lo protegido sin tener la llave, no solo probar llaves	Descompilar la aplicación para sacar la llave de firma

CODIFICAR, CIFRAR, RESUMIR Y FIRMAR NO SON LO MISMO

Cuatro operaciones que transforman datos y que se confunden todo el tiempo, incluso en informes de auditoría. La diferencia está en tres preguntas: si usan llave, si se pueden revertir y qué garantizan.

OPERACIÓN	¿USA LLAVE?	¿SE PUEDE REVERTIR?	QUÉ GARANTIZA
Codificar · Base64, hexadecimal	No	Sí: cualquiera, sin ningún secreto	Nada. Solo cambia la representación para que el dato viaje o se almacene
Cifrar	Sí	Sí, pero solo quien tiene la llave	Confidencialidad
Resumir	No	No: es de un solo sentido	Integridad, siempre que el resumen mismo esté protegido
Firmar	Sí, la privada	No se revierte: se verifica con la pública	Autenticidad y no repudio

// EL HALLAZGO QUE APARECE EN CASI TODA AUDITORÍA

Un campo en Base64 no está cifrado: cualquiera lo lee en un segundo, sin llave y sin herramientas especiales. Aparece en bases de datos, en cookies y en archivos de configuración, casi siempre junto a la frase «la contraseña está encriptada». **Esa frase es la primera que hay que verificar.**

NO ES UNA PROMESA, SON CUATRO

«Cifrado» no significa «protegido»: la criptografía presta cuatro servicios distintos, y cada uno exige su propio mecanismo.

// CONFIDENCIALIDAD

Que solo pueda leerlo quien deba.

Se consigue cifrando. Es el único de los cuatro que la mayoría de la gente asocia con la palabra criptografía.

En el caso: el cifrado de disco de los servidores apunta aquí, y aun así falla (H3).

// INTEGRIDAD

Que se pueda detectar si fue alterado.

Se consigue con funciones resumen y códigos de autenticación. Cifrar no da integridad por sí solo.

En el caso: nadie puede demostrar que los registros del servidor no fueron modificados.

// AUTENTICIDAD

Que se pueda establecer quién lo originó.

Se consigue con códigos de autenticación de mensajes o con firma digital, según de qué se trate.

En el caso: la aplicación autentica, pero autentica a la aplicación, no al usuario (H2).

// NO REPUDIO

Que el autor no pueda negar después haberlo hecho, y que un tercero pueda verificarlo.

Solo se consigue con firma digital y llave privada individual. Nunca con llave compartida.

En el caso: es el servicio ausente, y por eso el abogado se quedó sin respuesta.

CÓMO SE CONSIGUE CADA UNO

SERVICIO	MECANISMO	PREGUNTA QUE RESPONDE	SI FALTA...
Confidencialidad	Cifrado simétrico o asimétrico	¿Quién puede leerlo?	Cualquiera que acceda al dato lo entiende
Integridad	Funciones resumen, códigos de autenticación	¿Fue alterado?	No se puede distinguir el original de la copia manipulada
Autenticidad	Códigos de autenticación o firma digital	¿Quién lo originó?	Cualquiera puede hacerse pasar por otro
No repudio	Firma digital con llave privada individual	¿Puede negarlo después?	No hay prueba oponible ante un tercero

// EL ERROR MÁS CARO DE LA TABLA

El código de autenticación de mensajes da autenticidad, pero no da no repudio, porque las dos partes comparten la misma llave: cualquiera de las dos pudo haber generado el mensaje. La firma digital sí lo da, porque la llave privada la tiene una sola persona. Coopaburrá eligió lo primero y necesitaba lo segundo.

EJERCICIO RELÁMPAGO: ¿QUÉ SERVICIO FALLÓ?

Seis situaciones. Tres minutos en parejas. Para cada una, digan cuál de los cuatro servicios falló. Ojo: en algunas falló más de uno, y en una de ellas no falló ninguno.

N.º	SITUACIÓN
1	Un proveedor recibe un correo, aparentemente del gerente, pidiendo cambiar la cuenta bancaria para el próximo pago. Lo hace. El dinero se pierde.
2	Un disco duro con la base de datos de clientes se pierde en un taxi. Estaba cifrado con una llave que solo conoce el área de sistemas.
3	Una factura electrónica llega con el valor modificado. El emisor jura que envió otro valor y no hay forma de saber quién tiene razón.
4	Un empleado descarga la lista de salarios desde la base de datos de nómina, a la que tiene acceso legítimo de lectura.
5	Un cliente niega haber autorizado una transferencia. El banco muestra el registro del sistema. El cliente responde que ese registro lo hizo el banco.
6	Alguien intercepta el tráfico entre la aplicación y el servidor. Va cifrado con TLS 1.3 y no logra leer nada.

RESPUESTAS Y POR QUÉ

N.º	SERVICIO QUE FALLÓ	POR QUÉ
1	Autenticidad	El correo no estaba firmado. No hay forma de establecer quién lo originó. Es el fraude más común del país y no se resuelve cifrando.
2	Ninguno	La confidencialidad se mantuvo. Es la respuesta incómoda: aquí la criptografía funcionó. Lo que hay es un problema de custodia, no criptográfico.
3	Integridad y no repudio	No se detecta la alteración ni se puede probar quién dice la verdad. Es exactamente el escenario de la Ley 527.
4	Ninguno	El acceso era legítimo. Ningún mecanismo criptográfico detiene a quien tiene permiso. Es control de acceso, no criptografía.
5	No repudio	El registro lo produce una sola parte, así que no es oponible. Es, literalmente, el caso Coopaburrá.
6	Ninguno	Funcionó la confidencialidad en tránsito. Sirve para recordar que la criptografía sí hace bien su trabajo cuando está bien puesta.

LOS CUATRO SERVICIOS EN COOPABURRÁ

Este cuadro es el esqueleto de la primera parte del informe. Consérvenlo.

SERVICIO	¿LO TIENE?	EVIDENCIA EN EL CASO	HALLAZGO
Confidencialidad	Parcial	Cifrado de disco que solo protege con el servidor apagado; datos en claro en la base con el servidor encendido	H3, H4
Integridad	No	Los registros del servidor pueden modificarse sin dejar rastro. Esa fue la pregunta del abogado	H8
Autenticidad	Aparente	La aplicación firma, pero con llave compartida: autentica al programa, no a la persona	H2
No repudio	No	Ninguna llave privada individual. Ningún sello de tiempo. Ninguna entidad de certificación	H2, H7

DÓNDE VIVE LA CRIPTOGRAFÍA EN UNA ORGANIZACIÓN

Casi toda organización usa criptografía en más lugares de los que cree. Este mapa es el punto de partida de la entrega 1.

DÓNDE	QUÉ SERVICIO PRESTA	QUIÉN SUELE SABERLO EN COOPABURRÁ
Portal, aplicación y correo	Confidencialidad e integridad en tránsito	Infraestructura, a medias
Discos, bases de datos y respaldos	Confidencialidad en reposo	Quien lo configuró, si sigue en la empresa
Contraseñas y sesiones	Autenticación	La fábrica de software
Operaciones de la aplicación	Autenticidad e integridad de cada transferencia	La fábrica de software
Cajeros y medios de pago	Confidencialidad del PIN y autenticación del equipo	El fabricante y dos personas de 2019
Documentos firmados	Integridad y no repudio	Nadie: hoy es una imagen escaneada
Redes privadas con sedes y proveedores	Confidencialidad entre sitios	Redes, sin inventario

// LA COLUMNA QUE MÁS IMPORTA

La tercera. Donde la respuesta es «nadie» o «alguien que ya se fue», hay un hallazgo antes de mirar un solo algoritmo, y la entrega 1 tiene que decirlo con nombre y cargo.

LO QUE LA CRIPTOGRAFÍA NO PUEDE HACER

Antes de las reglas del oficio conviene marcar el límite. La criptografía es un control poderoso y estrecho, y sobrevenderla es la forma más común de dejar huecos en un diseño.

// NO GARANTIZA DISPONIBILIDAD

Cifrar no evita que un sistema se caiga ni que lo tumben.

El secuestro de datos usa criptografía impecable contra su dueño: la mejor prueba de que el algoritmo no sabe de quién es el dato.

// NO PROTEGE UN EXTREMO COMPROMETIDO

Si el teléfono del asociado o el servidor están infectados, el atacante ve el dato antes de cifrarlo o después de descifrarlo.

El canal cifrado llega intacto a un equipo que ya no es de confianza.

// NO DETIENE AL USUARIO ENGAÑADO

Quien entrega su contraseña o su código en un sitio falso está autorizando al atacante con sus propias credenciales.

La criptografía verifica llaves, no intenciones.

// NO SIRVE SI LA LLAVE SE FILTRA

Con la llave correcta el sistema funciona perfecto para quien la robó, y no deja ninguna señal.

Es el hallazgo H2: la llave de firma está al alcance de cualquiera que descargue la aplicación.

SECCIÓN

04

LAS REGLAS DEL OFICIO

Cuatro principios que llevan siglo y medio sin cambiar

KERCKHOFFS, 1883

Auguste Kerckhoffs, lingüista neerlandés, publicó en 1883 en el Journal des sciences militaires seis requisitos para un sistema de cifra militar. El segundo se volvió el principio fundacional de toda la criptografía moderna.

AUGUSTE KERCKHOFFS • LA CRYPTOGRAPHIE MILITAIRE • 1883

«El sistema no debe requerir ser secreto, y debe poder caer en manos del enemigo sin causar inconveniente.»

// LO QUE SIGNIFICA

Toda la seguridad debe descansar en la llave, no en que nadie sepa cómo funciona el mecanismo.

El algoritmo se puede publicar, auditar y discutir. La llave, no.

// POR QUÉ ES CIERTO

Los algoritmos se filtran, se descompilan y se deducen. Las personas que los conocen renuncian.

Un secreto que conocen muchos y que dura años no es un secreto: es una expectativa.

NO INVENTE CRIPTOGRAFÍA PROPIA

Es la regla más repetida del oficio y la más desobedecida. Estos son tres casos donde una organización sería decidió hacer su propio mecanismo, y el resultado.

CASO	QUÉ HICIERON	CÓMO TERMINÓ
Cifrado de redes inalámbricas WEP	Diseño propio sobre un algoritmo de flujo, con un vector de inicialización de solo 24 bits que se repetía	Roto públicamente en 2001. Hoy una red con WEP se descifra en minutos con herramientas libres
Tarjetas sin contacto MIFARE Classic	Algoritmo propietario mantenido en secreto, usado en transporte y control de acceso en todo el mundo	El algoritmo se dedujo por ingeniería inversa en 2008. Millones de tarjetas quedaron clonables
Coopaburrá, 2023	No inventaron el algoritmo: eligieron uno correcto. Inventaron el esquema de administración de la llave	38 transferencias no autorizadas y ninguna capacidad de probar nada

// EL MATIZ QUE IMPORTA

El tercer caso es el más instructivo porque muestra que la regla es más amplia de lo que suele enunciarse. No basta con no inventar el algoritmo: tampoco hay que inventar el protocolo, ni el esquema de llaves, ni el procedimiento de rotación. Esas partes también están estudiadas y estandarizadas.

ROTO FRENTE A MAL USADO

Cuando un sistema criptográfico falla en el mundo real, conviene saber dónde falló de verdad. Las categorías no se parecen en frecuencia.

ORIGEN DE LA FALLA	EJEMPLO	FRECUENCIA REAL
El algoritmo es débil	MD5 o SHA-1 para firmar, o DES	Poco frecuente: sistemas heredados
El algoritmo está mal configurado	Modo inadecuado o vector repetido	Frecuente
La llave está mal generada	Generador predecible, poca entropía	Frecuente y catastrófico
La llave está mal administrada	Compartida, en el código, nunca rotada	La más frecuente. Es el caso Coopaburrá
Se escogió el servicio equivocado	Autenticidad donde hacía falta no repudio	Frecuente y difícil de detectar

// CÓMO USAR ESTO EN EL INFORME

Cada hallazgo de Coopaburrá debería caer en una de estas cinco filas. La clasificación determina el tipo de solución y quién la ejecuta.

CONTRA QUIÉN SE PROTEGE

No existe «seguro». Existe «seguro frente a un adversario con ciertos recursos, durante cierto tiempo». Definir el adversario es parte del diseño, y es la conversación que Coopaburrá nunca tuvo.

ADVERSARIO	RECURSOS	QUÉ LO DETIENE EN EL CASO
Un curioso interno	Acceso legítimo de lectura a la base de datos	Cifrado a nivel de campo y registro de consultas. Hoy no hay ninguno de los dos
Un atacante remoto oportunista	Herramientas públicas, poco tiempo, busca blancos fáciles	Canal bien configurado y contraseñas bien almacenadas. Hoy fallan ambos
Alguien que descargó la aplicación	Un teléfono y un descompilador gratuito	Llaves individuales por usuario. Hoy hay una sola llave para todos
Un mensajero con el disco de respaldo	Acceso físico al medio durante el traslado	Llave separada del respaldo. Hoy viajan juntas en el mismo disco
Un adversario con capacidad de cómputo futura	Guarda hoy lo que podrá descifrar en diez años	Algoritmos resistentes. Es la sesión 6, y afecta a los créditos a veinte años

LOS CUATRO MODELOS DE ATAQUE

El criptoanálisis clasifica los ataques por lo que el atacante tiene en la mano. Es terminología estándar, aparece en toda la bibliografía, y un algoritmo moderno tiene que resistir los cuatro.

MODELO	QUÉ TIENE EL ATACANTE	DÓNDE APARECE EN EL CASO
Solo texto cifrado	Únicamente mensajes cifrados	Quien se lleve el disco de respaldo que viaja cada semana a Sabaneta
Texto claro conocido	Pares de mensaje y cifrado que él no escogió	Cada respaldo nocturno empieza con el mismo encabezado de volcado
Texto claro elegido	Puede hacer cifrar lo que quiera y ver el resultado	Cualquier asociado hace una transferencia y observa el código que la acompaña
Texto cifrado elegido	Puede hacer descifrar lo que quiera y observar cómo reacciona el sistema	Un servidor que responde distinto cuando el relleno está mal: el ataque de la sesión 2

// POR QUÉ IMPORTA EL ÚLTIMO

Un esquema que resiste el ataque de texto cifrado elegido resiste los otros tres. **Es el mínimo que se le exige hoy a cualquier cifrado**, y es la razón por la que la sesión 2 termina recomendando cifrado autenticado por defecto.

QUÉ SIGNIFICA «COMPUTACIONALMENTE INVIABLE»

La seguridad moderna no promete imposibilidad: promete que el ataque cuesta más tiempo del que existe. Conviene ver los números una vez, porque cambian la intuición para siempre.

LLAVE	LLAVES POSIBLES	GRUPO CRIMINAL · 10^{12} POR SEGUNDO	UN ESTADO · 10^{18} POR SEGUNDO
56 bits · DES	$7,2 \times 10^{16}$	20 horas	0,07 segundos
80 bits	$1,2 \times 10^{24}$	38.000 años	14 días
112 bits	$5,2 \times 10^{33}$	$1,6 \times 10^{14}$ años	164 millones de años
128 bits · AES-128	$3,4 \times 10^{38}$	$1,1 \times 10^{19}$ años	$1,1 \times 10^{13}$ años: 780 veces la edad del universo
256 bits · AES-256	$1,2 \times 10^{77}$	$3,7 \times 10^{57}$ años	$3,7 \times 10^{51}$ años

// LA CONCLUSIÓN PRÁCTICA

De 80 a 128 bits no hay un 60 % más de seguridad: hay 2^{48} veces más, unos 280 billones de veces. **Por eso nadie ataca AES probando llaves.** Se ataca la contraseña de la que salió la llave, el generador que la produjo o el lugar donde se guarda. Exactamente los hallazgos H1, H4 y H2.

CUÁNTO TIENE QUE DURAR EL SECRETO

La pregunta que casi nadie hace, y que determina qué algoritmo y qué longitud de llave hacen falta.

DATO DE COOPABURRÁ	VIDA ÚTIL DEL SECRETO	IMPLICACIÓN
Token de sesión del portal	Minutos	Puede usar mecanismos ligeros. Rotación constante
Contraseña de un asociado	Meses o años, según la política	Exige función de derivación con factor de trabajo, no un resumen simple
Saldo y movimientos	Años, mientras dure la relación	Cifrado en reposo con rotación de llaves planificada
Historial crediticio	Definido por la Ley 1266	El plazo lo fija la norma, no la tecnología
Contrato de crédito hipotecario	Hasta veinte años, y debe seguir siendo probatorio	Es el dato más exigente de la organización. Determina la migración criptográfica

// GUARDEN ESTA FILA

La última fila explica la sesión 6: un crédito firmado este año vence hacia 2046 y tiene que poder probarse hasta entonces.

LO QUE LLEVAMOS DEL PRIMER BLOQUE

01 La criptografía presta cuatro servicios distintos y no intercambiables

Confundir autenticidad con no repudio es lo que dejó a Coopaburrá sin respuesta ante su propio abogado.

02 La seguridad vive en la llave, no en el algoritmo

Kerckhoffs lo escribió en 1883 y sigue siendo el criterio con el que se juzga cualquier diseño.

03 Las fallas reales casi nunca son matemáticas

Son de configuración, de generación de llaves y, sobre todo, de administración de llaves.

04 No hay «seguro»: hay seguro frente a alguien, durante un tiempo

Definir el adversario y la vida útil del secreto es una decisión de diseño, no un detalle.

// DESPUÉS DEL DESCANSO

Vamos a la pieza de la que todo depende: la llave. De dónde sale, cuánta entropía necesita y qué pasa cuando se genera mal. Dos catástrofes reales y una demostración en vivo.

SECCIÓN

05

LA LLAVE

Bloque 2 · De dónde sale, cuánta entropía necesita y qué pasa cuando se genera mal

TODO DEPENDE DE LA LLAVE

Si la seguridad vive en la llave, entonces la pregunta operativa de todo el oficio es cómo se produce una llave que merezca ese nombre. Hay cuatro propiedades y las cuatro son obligatorias.

// 1 • IMPREDECIBLE

Nadie debe poder adivinarla ni reproducir el proceso que la generó.

Esto descarta el reloj del sistema, el número de proceso, el nombre de la empresa y el año.

// 2 • SUFICIENTEMENTE LARGA

El espacio de búsqueda debe ser tan grande que recorrerlo sea inviable con la tecnología del adversario.

128 bits de entropía real son suficientes hoy contra cualquier adversario clásico.

// 3 • CONOCIDA POR QUIEN DEBE

Una llave compartida entre 142.000 personas no es una llave: es un dato público con retraso.

Cada servicio criptográfico define cuántas partes pueden conocerla.

// 4 • CON UN CICLO DE VIDA DEFINIDO

Se genera, se distribuye, se usa, se rota, se archiva y se destruye.

Cada etapa tiene responsable. Es la sesión 6, y es lo que no existe en Coopaburrá.

ENTROPÍA, EN UNA FRASE

Entropía es la medida de lo que el adversario no sabe. Se cuenta en bits, y un bit de entropía equivale a duplicar el número de posibilidades que tendría que probar.

ORIGEN DE LA LLAVE	ENTROPÍA REAL	INTENTOS NECESARIOS
Un PIN de 4 dígitos	Unos 13 bits	10.000
Una palabra del diccionario	Unos 15 bits	Decenas de miles
«Cb4rr4-2023-HMAC-k3y»	Cero, una vez publicada	1. Está en el paquete de la aplicación
Contraseña humana de 8 caracteres	Entre 25 y 30 bits en la práctica	Cientos de millones. Horas con una tarjeta gráfica
32 bytes de un generador criptográfico	256 bits	Inalcanzable con tecnología clásica

// LA TRAMPA DE LA LONGITUD

La llave de Coopaburrá tiene veinte caracteres y parece robusta, pero la entropía no la da la longitud: la da lo que el adversario no sabe. Publicada dentro de la aplicación, vale cero: **una llave de veinte caracteres puede valer menos que un PIN.**

DOS GENERADORES QUE NO SON LO MISMO

// GENERADOR PSEUDOALEATORIO COMÚN

Diseñado para simulaciones, juegos y estadística. Rápido y reproducible a propósito.

Si se conoce el estado interno, toda la secuencia futura y pasada queda determinada.

Ejemplos típicos: las funciones de aleatoriedad por defecto de los lenguajes de programación.

Nunca debe usarse para generar llaves, vectores de inicialización, tokens ni contraseñas.

// GENERADOR CRIPTOGRÁFICO

Diseñado para que, conociendo cualquier parte de la salida, sea inviable deducir el resto.

Se alimenta de fuentes de entropía del sistema operativo: ruido de dispositivos, tiempos de interrupción, instrucciones del procesador.

Es el que hay que usar siempre, y en los lenguajes modernos suele estar a una línea de distancia.

Si duda cuál está usando, esa duda ya es un hallazgo.

DEBIAN, 2008: DOS LÍNEAS BORRADAS

El caso más didáctico de la historia reciente, porque nadie hizo nada malintencionado y el resultado fue devastador.

MOMENTO	QUÉ PASÓ
2006	Un mantenedor comenta dos líneas de código de la biblioteca criptográfica para silenciar una advertencia de una herramienta de análisis de memoria. La intención es limpiar el código.
2006 – 2008	Esas líneas alimentaban el generador con entropía. Sin ellas, la única fuente de variación que queda es el identificador del proceso.
Consecuencia	El espacio de llaves posibles se reduce de un número astronómico a unas 32.768 opciones. Todas las llaves generadas en ese periodo son enumerables.
Mayo de 2008	Se descubre. Hubo que regenerar y reemplazar llaves de servidores, certificados y llaves de acceso remoto en todo el mundo durante meses.

// LA MORALEJA OPERATIVA

El algoritmo era correcto, la implementación era la oficial y el mantenedor actuaba de buena fe. Lo que falló fue la entropía de entrada, que es invisible: una llave mal generada se ve exactamente igual que una buena. No hay forma de detectarlo mirando la llave.

PLAYSTATION 3, 2010: EL NÚMERO QUE DEBÍA CAMBIAR

El segundo caso muestra algo distinto: no falló la llave, falló un número que acompaña a cada firma y que debía ser distinto cada vez.

// QUÉ DEBÍA PASAR

El esquema de firma digital que usaba la consola exige un número aleatorio nuevo e irrepetible por cada firma.

Ese número no es la llave, pero si se repite, la matemática del esquema permite despejar la llave privada a partir de dos firmas.

// QUÉ PASÓ

La implementación usaba siempre el mismo valor fijo.

En diciembre de 2010, un grupo lo demostró públicamente y derivó la llave privada con la que el fabricante firmaba el software de la consola.

No se rompió el algoritmo de firma: se rompió un requisito de uso que estaba escrito en el estándar.

// LO QUE ESTOS DOS CASOS TIENEN EN COMÚN

En ninguno de los dos se rompió la matemática. En ambos falló la aleatoriedad: en uno, la que genera la llave; en otro, la que acompaña cada firma. Cuando lleguemos a firma digital en la sesión 4, este requisito va a reaparecer, y ustedes ya van a saber por qué importa.

DE DÓNDE SACAR ALEATORIEDAD BUENA

Referencia para el laboratorio y para el informe. La regla general: pídasela al sistema operativo, nunca la construya usted.

ENTORNO	LO QUE SE DEBE USAR	LO QUE NUNCA
Línea de comandos	openssl rand	Cadenas escritas a mano o derivadas de la fecha
Sistemas tipo Unix	El dispositivo de aleatoriedad del núcleo o la llamada al sistema correspondiente	Semillas fijas para «poder reproducir»
Java	La clase de aleatoriedad segura de la biblioteca estándar	La clase de aleatoriedad general
Python	El módulo de secretos o la función de bytes aleatorios del sistema	El módulo random
Navegador	La interfaz criptográfica del navegador	La función de aleatoriedad del lenguaje

GENERAR Y MIRAR UNA LLAVE

Demostración en vivo. Observen tres cosas: que cada ejecución da un resultado distinto, que la longitud es la que pedimos, y que no hay ningún patrón visible.

DEMOSTRACIÓN 1 • GENERACIÓN DE LLAVES

```
# 32 bytes = 256 bits de un generador criptográfico
```

```
openssl rand -hex 32
```

```
# la misma orden dos veces seguidas: nunca coincide
```

```
openssl rand -hex 32
```

```
# un vector de inicialización de 16 bytes
```

```
openssl rand -hex 16
```

// LA PREGUNTA PARA LA CLASE

Si ejecutamos esta orden un millón de veces, ¿cuál es la probabilidad de que dos resultados coincidan? Y una segunda, más incómoda: ¿cómo sabríamos si el generador de esta máquina está comprometido?

UNA CONTRASEÑA NO ES UNA LLAVE

Distinción que vamos a necesitar en la sesión 3, cuando arreglemos el hallazgo H1 de Coopaburrá.

// UNA LLAVE

La produce una máquina a partir de una fuente de entropía.

Tiene la longitud exacta que el algoritmo necesita.

Nadie la memoriza ni la escribe: se almacena y se custodia.

Su entropía es conocida y calculable.

// UNA CONTRASEÑA

La elige una persona, y las personas eligen mal y repiten.

Tiene longitud variable y entropía baja e impredecible.

Se memoriza, y por eso se parece a otras que la misma persona ya usó.

Para convertirla en llave hay que pasarla por una función de derivación con factor de trabajo deliberadamente lento.

// CONEXIÓN CON EL CASO

Coopaburrá guarda las contraseñas con un resumen simple y una sal compartida. Eso es tratar una contraseña como si fuera una llave, y es el hallazgo H1. En la sesión 3 vamos a ver por qué esa decisión hace que 142.000 contraseñas se puedan atacar todas a la vez en lugar de una por una.

CUÁNTA ENTROPÍA TIENE UNA CONTRASEÑA

Una llave de 128 bits tiene 128 bits de entropía porque la produjo una máquina al azar. Una contraseña tiene la entropía del procedimiento con que se escogió, y casi siempre es mucho menor de lo que aparenta.

SECRETO	CÓMO SE CALCULA	ENTROPÍA MÁXIMA
PIN de cuatro dígitos	$4 \times \log_2(10)$	13 bits
Seis minúsculas: la política de Coopaburrá	$6 \times \log_2(26)$	28 bits
Ocho caracteres al azar entre 94 símbolos	$8 \times \log_2(94)$	52 bits
Cinco palabras al azar de una lista de 7.776	$5 \times \log_2(7.776)$	65 bits
Llave AES-128 del generador del sistema	128 bits al azar	128 bits

// LA CUENTA QUE HAY QUE HACER CON EL HALLAZGO H1

Veintiocho bits son unos 270 millones de combinaciones. Una sola tarjeta gráfica calcula SHA-1 a razón de decenas de miles de millones por segundo: **recorre todas las contraseñas de seis minúsculas en menos de un segundo**. Y ese es el máximo teórico: las contraseñas que escoge la gente caen mucho antes.

SECCIÓN

06

POR QUÉ FALLA LO QUE PARECE SEGURO

De César a AES: sustitución, transposición y las lecciones que siguen vigentes

EL CIFRADO DE CÉSAR

Suetonio cuenta que Julio César desplazaba cada letra tres posiciones para su correspondencia militar. Es el punto de partida obligado, y se agota rápido: sirve para instalar el vocabulario.

EJEMPLO

Texto claro : COOPABURRA

Desplazamiento de 3

Texto cifrado: FRRSDEXUUD

Espacio de llaves: 25 desplazamientos posibles

// LO QUE INTRODUCE

La idea de algoritmo —desplazar— separada de la idea de llave —cuánto—.

Ese es el aporte conceptual y por eso vale la pena verlo.

// POR QUÉ MUERE

Veinticinco llaves posibles se prueban todas a mano en un par de minutos.

El espacio de llaves es tan pequeño que ni siquiera hace falta ser astuto.

SUSTITUCIÓN: UN ESPACIO ENORME QUE IGUAL CAE

El paso siguiente parece resolverlo todo: en vez de desplazar, se asigna a cada letra otra cualquiera. El espacio de llaves se vuelve gigantesco y el sistema sigue siendo indefendible.

26!PERMUTACIONES
POSIBLES **4×10^{26}** LLAVES
DISTINTAS**~88**BITS DE ESPACIO
DE LLAVES**Minutos**LO QUE TARDA
ROMPERLO

// LA LECCIÓN, Y ES LA MÁS IMPORTANTE DE ESTA SECCIÓN

Ochenta y ocho bits de espacio de llaves es una cifra respetable incluso para los estándares de hoy. Y sin embargo el sistema cae en minutos, porque el ataque no consiste en probar llaves: consiste en explotar una propiedad del texto que el cifrado no oculta. **Un espacio de llaves grande es necesario pero nunca suficiente.**

ANÁLISIS DE FRECUENCIAS

La sustitución conserva intacta la estructura estadística del idioma: cada letra cambia de nombre pero mantiene su frecuencia. Con un texto suficientemente largo, eso basta.

LETRA	FRECUENCIA APROXIMADA EN ESPAÑOL	LETRA	FRECUENCIA APROXIMADA EN ESPAÑOL
E	13,7 %	R	6,9 %
A	12,5 %	N	6,7 %
O	8,7 %	I	6,2 %
S	8,0 %	D	5,9 %

// CÓMO SE USA EN EL LABORATORIO

Se cuenta la frecuencia de cada símbolo del texto cifrado, se ordena, y se prueba la correspondencia con esta tabla. Las primeras dos o tres letras suelen acertar de una vez; el resto se completa por contexto, buscando palabras cortas y terminaciones frecuentes del español.

TRANSPOSICIÓN: MOVER SIN CAMBIAR

La otra gran familia de los cifrados clásicos. No se cambia ninguna letra: se cambian de lugar. La escítala espartana, una cinta enrollada en un bastón, ya lo hacía en el siglo V antes de Cristo.

TRANSPOSICIÓN POR COLUMNAS

Llave: CIFRA

Mensaje: PAGAR TODO EL VIERNES

C	I	F	R	A	← la llave encabeza las columnas
P	A	G	A	R	
T	O	D	O	E	← el mensaje se escribe por filas
L	V	I	E	R	
N	E	S	X	X	← la última fila se completa con relleno

Se leen las columnas en el orden alfabético de la llave: A, C, F, I, R

Cifrado: RERX PTLN GDIS AOVE AOEX

// LO QUE HAY QUE NOTAR

Las veinte letras del cifrado son exactamente las del mensaje, más dos de relleno. **Ninguna cambió; todas se movieron.** Esa diferencia con la sustitución es la que permite reconocer en segundos qué clase de cifrado se tiene delante.

CÓMO SE DELATA Y CÓMO SE ROMPE UNA TRANSPOSICIÓN

Cada familia deja una huella distinta, y aprender a leerla es el primer oficio del criptoanalista.

// CÓMO SE DELATA

El análisis de frecuencias devuelve exactamente la distribución del español: la E cerca del 14 %, la A cerca del 12,5 %, la O cerca del 9 %.

Con una sustitución eso no pasa, porque las letras cambiaron. Con una transposición pasa siempre.

Es la primera prueba que hace un analista: le dice qué familia tiene delante antes de intentar nada más.

// CÓMO SE ROMPE

Se prueban anchos de columna y se buscan combinaciones frecuentes del idioma: QU, ES, EN, DE, LA.

El espacio de llaves útil es pequeño, y cada acierto parcial ayuda a encontrar el siguiente, como en un crucigrama.

La doble transposición resiste mucho más, y se usó en operaciones militares hasta mediados del siglo XX.

// LA LECCIÓN QUE LLEGA HASTA AES

La sustitución sola cae por frecuencias; la transposición sola cae por anagramas. **Combinadas y repetidas son mucho más fuertes que cada una por separado.** Es la idea que Claude Shannon formalizó en 1949, y está dentro de todo cifrado de bloque moderno.

VIGENÈRE Y LA LLAVE QUE SE REPITE

Durante tres siglos se consideró indescifrable. La idea es buena y sobrevive hasta hoy: usar una llave que cambie el desplazamiento letra por letra, de modo que la misma letra del texto claro no produzca siempre el mismo símbolo.

EJEMPLO CON LA LLAVE «LLAVE»

Texto claro : C O O P A B U R R A

Llave : L L A V E L L A V E ← se repite cíclicamente

Texto cifrado: N Z O K E M F R M E

// POR QUÉ RESISTE EL ANÁLISIS SIMPLE

La misma letra produce símbolos distintos según su posición.

Las frecuencias del idioma quedan aplanadas y la tabla anterior deja de servir directamente.

// POR QUÉ CAE DE TODOS MODOS

La llave se repite. Si mide cinco letras, el texto son en realidad cinco cifrados de César intercalados.

Kasiski publicó en 1863 cómo deducir la longitud de la llave a partir de secuencias repetidas. Hallada la longitud, se aplica el análisis de frecuencias a cada posición.

ENIGMA: LA MÁQUINA NO FALLÓ, FALLÓ LA OPERACIÓN

Vigenère mecanizado: rotores que cambian la sustitución con cada letra y un tablero de conexiones. La versión del ejército alemán admitía unos 159 trillones de configuraciones. Cayó igual, y por las mismas razones que Coopaburrá.

DEBILIDAD	DE QUÉ TIPO ERA	SU EQUIVALENTE EN EL CASO
Una letra nunca se cifraba como sí misma	Defecto de diseño, pequeño pero explotable	Poco frecuente hoy: es la categoría del algoritmo débil
Mensajes con texto predecible: partes del clima, fórmulas fijas	Texto claro conocido	El encabezado idéntico de cada respaldo nocturno
La llave de cada mensaje se transmitía dos veces al inicio	Repetición que expuso la estructura	La misma llave de firma en todas las versiones desde 2023
Operadores que escogían llaves obvias o repetidas	Mala generación de llave	La contraseña de seis caracteres

// QUIÉNES LA ROMPIERON Y CÓMO

Los matemáticos polacos Rejewski, Różycki y Zygalski desde 1932, y después el equipo de Bletchley Park con Turing. **Ninguno atacó el espacio de llaves: atacaron la operación.** Es la lección de historia más útil para un auditor.

EL ÚNICO CIFRADO PERFECTO

Si el problema de Vigenère es que la llave se repite, la solución evidente es que no se repita nunca. Ese sistema existe, se llama cuaderno de un solo uso, y Claude Shannon demostró en 1949 que es matemáticamente irrompible.

CONDICIÓN	POR QUÉ ES INDISPENSABLE
La llave es tan larga como el mensaje	Si fuera más corta habría que repetirla, y volvería el ataque de Kasiski
La llave es perfectamente aleatoria	Cualquier patrón en la llave se traslada al texto cifrado
La llave se usa una sola vez	Dos mensajes con la misma llave se pueden combinar y la llave se cancela, dejando los textos relacionados
La llave se distribuye en secreto	Hay que hacerle llegar al destinatario tantos bits secretos como bits vaya a enviar

// LA PARADOJA QUE ENSEÑA TODO EL OFICIO

Es perfecto e inservible. Para enviar un gigabyte en secreto hay que haberle entregado antes al destinatario un gigabyte de llave en secreto, con lo cual el problema no se resolvió: se movió. **Toda la criptografía moderna es la búsqueda de un compromiso practicable entre seguridad y manejabilidad de la llave.**

LA REUTILIZACIÓN DE LLAVE, QUE NO ES HISTORIA

La tercera condición del cuadro anterior no es una curiosidad histórica: es un error que se sigue cometiendo con algoritmos modernos, y lo vamos a ver en funcionamiento en el laboratorio.

POR QUÉ NUNCA SE REPITE UNA LLAVE DE FLUJO

Si $C1 = M1 \oplus K$ y $C2 = M2 \oplus K$ (la misma llave K dos veces)

entonces $C1 \oplus C2 = M1 \oplus M2$ ← la llave desaparece

y quien tenga los dos textos cifrados obtiene una relación directa entre los dos mensajes, sin conocer K jamás.

// DÓNDE REAPARECE ESTO

En la sesión 2, cuando veamos modos de operación, el vector de inicialización repetido produce exactamente este efecto sobre AES. Y en la sesión 4, el número que se repitió en el caso de la consola es la misma idea aplicada a firma digital. Es un solo error con tres disfraces.

CONFUSIÓN Y DIFUSIÓN: LO QUE SHANNON DEJÓ ESCRITO

En 1949 Claude Shannon publicó el trabajo que convirtió la criptografía en ciencia. Demostró por qué el cuaderno de un solo uso es perfecto y dejó dos principios de diseño que siguen gobernando todo cifrado moderno.

// CONFUSIÓN

Que la relación entre la llave y el texto cifrado sea lo más compleja posible.

Cada bit del cifrado debe depender de muchas partes de la llave, de modo que conocer pedazos del cifrado no revele pedazos de la llave.

Se consigue con **sustitución** no lineal.

// DIFUSIÓN

Que cada bit del texto claro influya en muchos bits del cifrado.

Cambiar una sola letra del mensaje debe cambiar, en promedio, la mitad del resultado: el efecto avalancha que van a medir en la sesión 3.

Se consigue con **transposición** y mezcla.

// LA CONSECUENCIA

Los patrones estadísticos del idioma, que son los que rompen a César, a la sustitución y a la transposición, quedan disueltos en el cifrado. **El análisis de frecuencias deja de funcionar**, y el atacante vuelve a quedar frente al espacio de llaves completo.

DE LOS CIFRADOS CLÁSICOS A AES

Lo que van a ver el jueves ya lo conocen. AES es sustitución y transposición, combinadas con la llave y repetidas diez veces o más. Lo nuevo no es la idea: es el rigor con que se diseñó y se analizó en público.

OPERACIÓN DE CADA RONDA	IDEA CLÁSICA DE LA QUE VIENE	PRINCIPIO
Sustituir cada byte con una tabla fija	Sustitución, con una tabla construida para no dejar patrones	Confusión
Desplazar las filas del bloque	Transposición	Difusión
Mezclar cada columna	Cada byte pasa a depender de los otros tres de su columna	Difusión
Combinar con la llave de la ronda	La misma operación del cuaderno de un solo uso	La única parte secreta
Repetir 10, 12 o 14 veces	Según la llave sea de 128, 192 o 256 bits	Hasta que la salida sea indistinguible del azar

// POR QUÉ NADIE LO DISCUTE

Quince candidatos, un concurso público abierto a cualquier criptoanalista del mundo y un ganador, Rijndael, escogido en 2000. **Veinticinco años después, el mejor ataque conocido contra AES completo es apenas mejor que probar todas las llaves.** Eso es lo que significa un algoritmo estándar.

SECCIÓN

07

LABORATORIO 1

Romper tres cifrados clásicos y entender por qué cayeron

OBJETIVO Y ENTREGABLE

Treinta minutos, en los equipos de tres que se conformaron al inicio. No se trata de resolver los retos: se trata de documentar por qué se pudieron resolver. Lo que no se cierre en clase se termina como trabajo independiente.

01 Ejercicio 1 · Un desplazamiento

Descifrar un mensaje cifrado con César sin conocer el desplazamiento. Registrar cuántos intentos hicieron falta y cuánto tiempo tomó.

02 Ejercicio 2 · Una sustitución

Romper un texto cifrado por sustitución usando análisis de frecuencias. Entregar la correspondencia deducida y el método seguido.

03 Ejercicio 3 · Dos mensajes, una llave

Se les entregan dos textos cifrados con la misma llave de flujo. Combinarlos y explicar qué información aparece y por qué.

// LO QUE SE ENTREGA

Una página por equipo, al final del bloque: para cada ejercicio, el resultado obtenido, el método empleado y —lo que realmente se evalúa— **qué propiedad del cifrado permitió el ataque**. Un ejercicio resuelto sin esa explicación vale la mitad.

ENTORNO DE TRABAJO

Todo el laboratorio funciona sin conexión a internet y sin permisos de administrador: Python se instala para el usuario, y la librería también. Desde la sesión 2, los ejercicios con OpenSSL van en Git Bash en Windows —no en cmd ni PowerShell—; en macOS y Linux, en la Terminal.

// HERRAMIENTA PRINCIPAL

Una página de utilidades criptográficas que se ejecuta dentro del navegador, sin enviar nada a ningún servidor.

Se les entrega el archivo; se abre con doble clic y funciona aunque la sala no tenga internet.

// PYTHON, EN TODOS LOS LABORATORIOS

Python 3 con su biblioteca estándar alcanza para hoy. Desde la sesión 2 se suma la librería cryptography.

El análisis de frecuencias son diez líneas de código, y escribirlas enseña más que usar la herramienta.

// ADVERTENCIA PARA TODO EL MÓDULO

No carguen material del caso ni textos de los ejercicios en servicios en línea de terceros. Además de la regla 5 del caso, es una costumbre profesional: lo que se pega en un sitio público deja de ser confidencial en ese instante.

LABORATORIO 1 · EL EJERCICIO EN PYTHON

Como pide la carta descriptiva: implementar y analizar con librerías estándar. Hoy, el ejercicio 2 hecho con código, más una prueba sobre generadores.

```
LABORATORIO 1 · PYTHON 3, SOLO BIBLIOTECA ESTÁNDAR
```

```
from collections import Counter
import random, secrets
```

```
# Ejercicio 2 con código: frecuencias del texto cifrado
cifrado = open("ejercicio2.txt", encoding="utf-8").read().upper()
letras = [c for c in cifrado if c.isalpha()]
for letra, n in Counter(letras).most_common(8):
    print(letra, round(100 * n / len(letras), 1), "%")
```

```
# Dos generadores: uno que se puede repetir y uno que no
random.seed(2019); print(random.getrandbits(128)) # siempre el mismo
print(secrets.token_hex(16))                     # 128 bits del sistema
```

```
// LAS DOS PREGUNTAS QUE VAN EN EL INFORME
```

¿Qué letra del cifrado corresponde a la E, y cómo lo saben? Y ejecuten la línea del generador tres veces: **¿por qué el primer número sale siempre igual, y qué tiene que ver con Debian en 2008?**

LO QUE LLEVAMOS DE LA SESIÓN

01

Cuatro servicios, no uno

Y el que le faltaba a Coopaburrá —no repudio— no se consigue con el mecanismo que eligieron.

02

La seguridad vive en la llave

Kerckhoffs, 1883. Sigue siendo el criterio con el que se juzga cualquier diseño.

03

Una llave sin entropía no es una llave

Debian y la consola de videojuegos lo demuestran: el algoritmo puede ser perfecto y el sistema caer igual.

04

Un espacio de llaves grande no basta

La sustitución tiene ochenta y ocho bits y cae en minutos, porque el ataque no prueba llaves.

05

Repetir una llave la destruye

Es el mismo error en el cuaderno de un solo uso, en los modos de cifrado y en la firma digital.

PRIMERA PARTE DEL PRODUCTO

Se entrega al inicio de la sesión 2. Es el hallazgo H8 y la base de todo lo que sigue. La guía de la entrega explica cómo llenar cada columna.

COLUMNA DEL INVENTARIO	QUÉ SE REGISTRA	DÓNDE SALE EL DATO
Dónde está la criptografía	Sistema, canal o proceso donde se usa	Parte 3 del caso
Para qué sirve ahí	Cuál de los cuatro servicios pretende dar	Lo deducen ustedes
Qué algoritmo y qué versión	Nombre, modo y longitud; «desconocido» es respuesta válida y reveladora	Partes 3 y 8 · anexo técnico
Qué llave lo protege	Cuántas hay, quién las conoce, dónde se guardan	Partes 7 y 8 · anexo técnico
Quién responde por ella	Nombre y cargo de la Parte 2 del caso	Parte 2
Cuándo vence o se rota	Fecha conocida o «nunca se ha rotado»	Partes 7 y 10 · anexo

// CRITERIO DE EVALUACIÓN

No se evalúa que esté completo: es imposible completarlo. Se evalúa que **las casillas vacías estén marcadas como desconocidas** y que se diga a quién preguntarle. El **anexo técnico** del caso trae, por sistema, el algoritmo y la llave que la Parte 3 no detalla.

TRABAJO INDEPENDIENTE HASTA LA SESIÓN 2

8 h

TOTAL ENTRE
MARTES Y JUEVES

3,5 h

LECTURA
PREVIA

4,5 h

INVENTARIO E INFORME
DEL LABORATORIO 1

Lectura previa · 3,5 horas

El caso Coopaburrá y su anexo técnico

Las catorce páginas del caso más el anexo, que trae la evidencia por sistema. 1,5 horas. El jueves se asume leído, en especial las partes 3, 7, 8 y 10 y el anexo, que alimentan el inventario.

Katz y Lindell (2020)

Introduction to Modern Cryptography, capítulos 1 y 2: cifrados clásicos, principios de la criptografía moderna y secreto perfecto. Una hora.

NIST SP 800-38A

Recommendation for Block Cipher Modes of Operation, sección 6: los modos ECB, CBC y CTR. Una hora. Es la base del bloque 3.

// CONDICIÓN DE ENTRADA A LA SESIÓN 2

El jueves no se explica qué es un modo de operación: se discute cuál escoger. Las 4,5 horas de elaboración son el inventario (3 h, en equipo, con la guía de la entrega) y el cierre del informe del laboratorio (1,5 h). El quiz 1 incluye preguntas sobre estas lecturas.

LO QUE VIENE EL JUEVES

Sesión 2: cifrado simétrico. El bloque más práctico del módulo y el que ataca directamente dos hallazgos del caso.

// BLOQUE 1 • AES Y LOS MODOS DE OPERACIÓN

Qué es realmente AES y qué no es.

Por qué el modo de operación importa más que el algoritmo, y por qué elegirlo mal deja los datos a la vista aunque estén «cifrados».

Cifrado autenticado: el modo que da confidencialidad e integridad al tiempo, y por qué hoy es el que se debe usar por defecto.

// BLOQUE 2 • LABORATORIO Y HALLAZGOS

Una demostración que no se olvida: el escudo de la Institución cifrado con AES-256, todavía perfectamente reconocible.

Análisis de la línea real del script de respaldo de Coopaburrá, que tiene tres errores distintos y solo uno es evidente.

Entrega y realimentación de la primera parte del inventario.

SIGLAS DE LA SESIÓN · 1 DE 2

AES

Advanced Encryption Standard — Estándar de cifrado avanzado. Cifrado simétrico de bloque adoptado por el NIST en 2001.

Base64

Codificación que representa datos binarios con 64 caracteres imprimibles. No es cifrado: se revierte sin llave.

CSPRNG

Cryptographically Secure Pseudorandom Number Generator — Generador de números aleatorios apto para criptografía.

DES

Data Encryption Standard — Estándar de cifrado de datos de 1977, con llave de 56 bits. Retirado.

ECB / CBC / CTR

Electronic Codebook, Cipher Block Chaining, Counter — Modos de operación de un cifrado de bloque. Sesión 2.

H1 ... H8

Los ocho hallazgos del diagnóstico criptográfico de Coopaburrá, numerados como en el documento del caso.

HMAC

Hash-based Message Authentication Code — Código de autenticación de mensajes basado en una función resumen. Sesión 3.

IV

Initialization Vector — Vector de inicialización. Valor que debe cambiar en cada cifrado. Sesión 2.

NIST

National Institute of Standards and Technology — Instituto Nacional de Estándares y Tecnología de Estados Unidos.

OTP

One-Time Pad — Cuaderno de un solo uso. El único cifrado con secreto perfecto demostrado.

Toda sigla utilizada en la sesión aparece en el glosario con su forma completa en el idioma original y su equivalencia en español.

SIGLAS DE LA SESIÓN · 2 DE 2

PIN

Personal Identification Number — Número de identificación personal.

PS3

PlayStation 3 — Consola cuya llave de firma se recuperó en 2010 porque un número que debía cambiar era constante.

RSA

Rivest, Shamir y Adleman — Algoritmo de llave pública de 1977, nombrado por sus autores. Sesión 4.

SHA-1

Secure Hash Algorithm 1 — Función resumen de 160 bits, rota desde 2017. La que usa Coopaburrá para contraseñas.

SQL

Structured Query Language — Lenguaje de consulta de bases de datos. El respaldo del caso es un volcado SQL.

SSL / TLS

Secure Sockets Layer / Transport Layer Security — Protocolos de canal seguro. Sesión 5.

XOR

Exclusive OR — O exclusivo. Operación bit a bit con la que se combina la llave en el cuaderno de un solo uso.

MD5

Message Digest 5 — Función resumen de 128 bits de 1992. Rota desde 2004: no sirve para nada que exija seguridad.

SP

Special Publication — Serie de publicaciones técnicas del NIST, como la SP 800-38A sobre modos de operación.

WEP

Wired Equivalent Privacy — Primer cifrado de redes inalámbricas. Roto en 2001 y reemplazado por WPA.

Toda sigla utilizada en la sesión aparece en el glosario con su forma completa en el idioma original y su equivalencia en español.

REFERENCIAS DE LA SESIÓN

Katz, J. y Lindell, Y. (2020).	Introduction to modern cryptography (3. ^a ed.). CRC Press.	Capítulos 1 y 2: cifrados clásicos, principios y secreto perfecto · lectura previa
Stallings, W. (edición vigente).	Cryptography and network security: Principles and practice. Pearson.	Técnicas clásicas de cifrado: sustitución y transposición
Kerckhoffs, A. (1883).	La cryptographie militaire. Journal des sciences militaires, 9, 5–38.	Los seis requisitos; el segundo es el principio de Kerckhoffs
Shannon, C. E. (1949).	Communication theory of secrecy systems. Bell System Technical Journal, 28(4), 656–715.	Secreto perfecto, confusión y difusión
Singh, S. (2000).	Los códigos secretos. Debate.	De César a Enigma: la parte histórica de la sesión
NIST. (2015).	SP 800-90A Rev. 1: Recommendation for random number generation using deterministic random bit generators.	Qué es un generador determinista y cómo se siembra
NIST. (2001).	SP 800-38A: Recommendation for block cipher modes of operation.	Sección 6 · lectura previa de la sesión 2

// ACCESO A LAS FUENTES

Las publicaciones del NIST son de acceso libre. Los libros se consultan en las bases de datos de la Institución o en la biblioteca; no está autorizado el uso de copias obtenidas por otros medios.